

Индивидуальный проект. Стадия №4

Отчет

Зубов Иван Александрович

Содержание

1	Цель работы	5
2	Выполнение лабораторной работы	6
3	Выводы	9

Список иллюстраций

2.1	ip адрес	6
2.2	Используем команду nikto	7
2.3	Анализ вывода команды	7
2.4	Анализ вывода команды	8
2.5	Анализ вывода команды	8

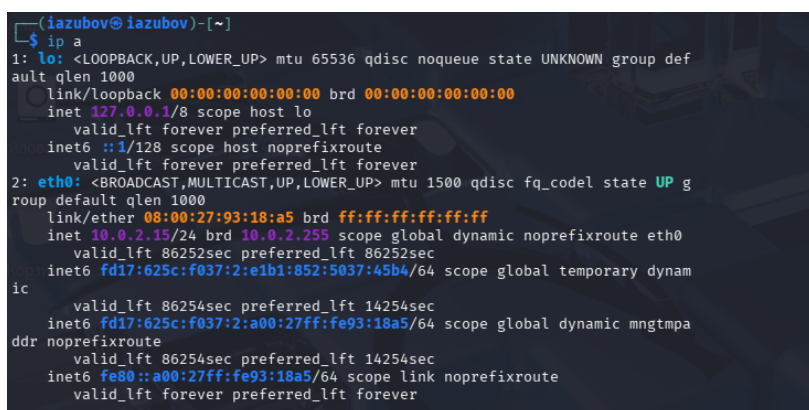
Список таблиц

1 Цель работы

Провести сканирование веб-сервера DVWA с использованием nikto. Выявить опасные настройки и файлы.

2 Выполнение лабораторной работы

Узнаем ip адрес для дальнейшей работы с nikto.



```
(iazubov@iazubov)~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:93:18:a5 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86252sec preferred_lft 86252sec
    inet6 fd17:625c:f037:2:e1b1:852:5037:45b4/64 scope global temporary dynam
ic
        valid_lft 86254sec preferred_lft 14254sec
    inet6 fd17:625c:f037:2:a00:27ff:fe93:18a5/64 scope global dynamic mngtmpa
ddr noprefixroute
        valid_lft 86254sec preferred_lft 14254sec
    inet6 fe80::a00:27ff:fe93:18a5/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Рисунок 2.1: ip адрес

Выполним базовое сканирование с помощью nikto и проанализируем вывод команды

```
(iazubov@iazubov)-[~]
$ nikto -h http://10.0.2.15/DVWA/
- Nikto v2.5.0

+ Target IP: 10.0.2.15
+ Target Hostname: 10.0.2.15
+ Target Port: 80
+ Start Time: 2026-04-23 21:44:45 (GMT3)

+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: h
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the
user agent to render the content of the site in a different fashion to the MI
ME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
ities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be p
resent.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the direct
ory structure.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp
the directory structure and learn more about the site.
+ 8102 requests: 0 error(s) and 16 item(s) reported on remote host
+ End Time: 2026-04-23 21:45:08 (GMT3) (23 seconds)

+ 1 host(s) tested
```

Рисунок 2.2: Используем команду nikto

Результаты для представленного ряда строк на фото таковы: Заголовок X-Frame-Options не установлен, что делает приложение уязвимым к атакам Clickjacking — злоумышленник может встроить страницу в невидимый фрейм и обманом заставить пользователя выполнить нежелательные действия. Отсутствие заголовка X-Content-Type-Options позволяет браузеру неправильно определять тип файлов (MIME-сниффинг), из-за чего вредоносный код может быть выполнен под видом изображения или другого безопасного файла. Также не установлен заголовок X-XSS-Protection, что повышает риск успешного внедрения и выполнения межсайтовых скриптов (XSS-атак).

```
+ Server: Apache/2.4.65 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: h
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the
user agent to render the content of the site in a different fashion to the MI
ME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
ities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
```

Рисунок 2.3: Анализ вывода команды

Обнаружено несколько директорий с включённым индексным просмотром (Directory Indexing): /DVWA/config/, /DVWA/tests/, /DVWA/database/ и /DVWA/docs/. Это означает, что любой пользователь может открыть эти папки в браузере и увидеть полный список файлов. Особую опасность представляют директории config/ (может содержать файлы с паролями от базы данных) и database/ (файлы базы данных), а также tests/

```
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
```

Рисунок 2.4: Анализ вывода команды

Обнаружены следующие Git-файлы: /DVWA/.git/index, /DVWA/.git/HEAD, /DVWA/.git/config, а также файлы .gitignore и .dockerignore. Присутствие этих файлов на рабочем веб-сервере является грубой ошибкой конфигурации, поскольку любой пользователь может получить к ним доступ через браузер. Из этих файлов злоумышленник может извлечь ценную информацию: структуру директорий проекта, историю изменений, комментарии разработчиков, а в некоторых случаях — пароли или ключи, случайно добавленные в репозиторий.

```
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
```

Рисунок 2.5: Анализ вывода команды

3 Выводы

В ходе сканирования DVWA с помощью Nikto выявлены отсутствие защитных HTTP-заголовков, открытый доступ к директориям `config/`, `database/`, `tests/`, `docs/` и наличие Git-файлов, что подтверждает небезопасную конфигурацию веб-сервера